

PaySafe India

PCI DSS v4.0 GAP ANALYSIS

Cardholder Data Environment Scope, Requirement-by-Requirement Compliance Posture, Evidence-Sampled Findings, Compensating Controls Analysis, and Remediation Roadmap

Document Title	PaySafe India - PCI DSS v4.0 Gap Analysis
Assessment Reference	PSI-PCI-2026-01
Subject Organization	PaySafe India (Digital Payments, UPI, BNPL Lending & Card Processing)
Card Processing Role	Issuer and Acquirer Processing Services (in-house CDE)
Assessment Period (Fieldwork)	6 July 2026 - 20 July 2026
Report Issue Date	22 July 2026
Document Classification	Internal - Confidential
Version	v1.0 - Final
Lead Assessor	[Ayush Joshi] - Qualified Security Assessor, engaged via SentinelGrid QSAC
Approved By	Chief Information Security Officer (CISO); Head of Compliance
Related Deliverables	ISO/IEC 27001:2022 Gap Analysis (v1.0); TPRM Framework (v1.0); Internal Audit Report - ISMS Control Effectiveness (PSI-IA-2026-04)

Table of Contents

Table of Contents	2
1. Executive Summary	4
1.1 Overall Compliance Posture	4
1.2 Headline Risk	4
1.3 Top Remediation Priority	5
2. Cardholder Data Environment (CDE) Scope Definition	5
2.0 Entity Classification & Reporting Boundary	5
2.1 Scoping Logic	6
2.2 In-Scope Systems.....	6
2.3 Out-of-Scope Systems	6
2.4 Segmentation Assessment	6
2.5 Scope Justification - Excluded Business Lines (UPI, BNPL Lending).....	7
3. Gap Analysis Master Table	7
3.0 Risk-Rating and Sampling Methodology.....	7
3.1 Goal 1 - Build and Maintain a Secure Network and Systems	8
3.2 Goal 2 - Protect Account Data	8
3.3 Goal 3 - Maintain a Vulnerability Management Program	9
3.4 Goal 4 - Implement Strong Access Control Measures	9
3.5 Goal 5 - Regularly Monitor and Test Networks	10
3.6 Goal 6 - Maintain an Information Security Policy.....	10
4. Detailed Findings - Evidence Sampling	10
4.1 Finding 01 - Network Security Control Rule-Set Review Lapsed (Req 1.2.7, Req 1.4.1)	10
4.2 Finding 02 - Legacy Database Replicas Retain Default Remote-Root Access (Req 2.2.2)	11
4.3 Finding 03 - Unmasked PAN Retained in Settlement Export Files Beyond Business Need (Req 3.2.1, Req 3.5.1).....	11
4.4 Finding 04 - SAST Not Integrated into Admin Portal CI/CD; Dependency Scanning Ad Hoc (Req 6.2.4, Req 6.3.2).....	11
4.5 Finding 05 - Privileged Access Review for Card-Vault Roles Lapsed Three Quarters (Req 7.2.4, Req 7.2.5/7.2.5.1)	12
4.6 Finding 06 - MFA Not Enforced for Third-Party Vendor Remote Support Access (Req 8.4.2, Req 8.2.2)	12
4.7 Finding 07 - No Automated Log Review or Correlation for Cardholder Data Access (Req 10.4.1.1)	13

4.8 Finding 08 - Segmentation Testing Not Re-Performed After Significant Change (Req 11.4.6)	13
5. Compensating Controls Analysis	13
5.1 Compensating Control 1 - Interim Protection for the Settlement PAN Export (Finding 03, Req 3.5.1)	13
5.2 Compensating Control 2 - Hardened Jump Host for Vendor Remote Support (Finding 06, Req 8.4.2)	14
5.3 Compensating Control 3 - Proposed Segmentation for Legacy Analytics Database Access (Finding 02, Req 2.2.2) - Not Approved	15
6. Remediation Roadmap	16
6.1 Immediate (0-30 days) - Critical Findings	16
6.2 Short-term (30-90 days) - High Findings	17
6.3 Medium-term (90-180 days) - Medium Findings	17
7. DPDP 2023 Alignment Note	17
7.1 Requirement 3 and Data Minimization / Storage Limitation	18
7.2 Requirement 7 and Purpose Limitation / Access Governance	18
7.3 Compounding Regulatory Exposure	18

(Right-click the table above and select "Update Field" > "Update entire table" to populate page numbers after opening this document in Word.)

1. Executive Summary

PaySafe India's card processing platform - spanning issuing and acquiring - stores, processes, and transmits cardholder data across four core systems, and this assessment finds the environment Partially Compliant against PCI DSS v4.0: of the twelve requirements, three are rated Red, five Amber, and four Green. None of the twelve is a clean pass without qualification, and none is a total failure either; the pattern that emerges is a security programme with real controls in place that have not been operated with the discipline the standard requires.

1.1 Overall Compliance Posture

PCI DSS Goal	Requirements	Posture
1. Build and Maintain a Secure Network and Systems	Req 1-2	Both Amber
2. Protect Account Data	Req 3-4	Req 3 Red, Req 4 Green
3. Maintain a Vulnerability Management Program	Req 5-6	Req 5 Green, Req 6 Amber
4. Implement Strong Access Control Measures	Req 7-9	Req 7 Red, Req 8 Amber, Req 9 Green
5. Regularly Monitor and Test Networks	Req 10-11	Req 10 Red, Req 11 Amber
6. Maintain an Information Security Policy	Req 12	Green

The three Red requirements share a common thread: each is a case where a technical control that would normally satisfy the requirement exists somewhere in the environment, but a specific process, legacy dependency, or operational gap prevents it from actually closing the risk. Req 3 fails because a settlement reconciliation job routinely exports unmasked PAN to a file share that far outdated retention limits. Req 7 fails because privileged access to the card vault has gone three consecutive quarters without the review the access control policy mandates. Req 10 fails because the SIEM ingesting CDE logs has never had correlation rules built for anomalous cardholder data access, so log collection is happening but log review, in any meaningful sense, is not.

1.2 Headline Risk

The single finding that should worry PaySafe India's board more than any other is the unmasked PAN export under Req 3.5.1 (Finding 03, Section 4.3). It is the only Red finding where cardholder data is sitting outside the tokenization boundary in a form a threat actor could exfiltrate and use directly, and it has been running long enough that the retained file archive now holds several months of live PAN data with access controls no stronger than the general file server's. Every other finding in this report increases the probability of a breach; this one increases both the probability and the blast radius.

This is v1.0 of PaySafe India's PCI DSS gap analysis, so there is no prior-cycle report to formally compare against. That said, Finding 01's rule-set review gap ("not evidenced for two consecutive review cycles," Section 4.1) and Finding 05's lapsed quarterly review ("since Q3 2025," Section 4.5) both describe control lapses that predate this assessment's fieldwork window. PaySafe India's compliance function should confirm with Internal Audit and prior IT-GRC records whether either condition was already flagged in an earlier internal review; if either is a repeat finding, that materially raises its severity and should be reflected as such at next re-assessment.

The RAG and Critical/High/Medium ratings used throughout this report are qualitative, which is appropriate for a gap analysis of this scope but does not, on its own, give the board a loss-magnitude figure to weigh against remediation spend. Given the board-level language above, PaySafe India's risk function should consider supplementing Finding 03 in particular with a likelihood/impact scoring or a FAIR-style annualized loss expectancy estimate before this finding is presented to the board or folded into the enterprise risk register - the qualitative rating in this report is not a substitute for that quantitative step.

1.3 Top Remediation Priority

Fix the settlement export first. Everything else in the Immediate horizon (Section 6.1) can run in parallel, but the PAN export is the one finding where every additional day of exposure is additional cardholder data sitting in the wrong place. A short-term compensating control is proposed in Section 5.1 to reduce the exposure within days rather than the months a proper fix to the reconciliation platform will take, and PaySafe India should not treat the compensating control as a substitute for the underlying remediation - it buys time, it does not close the gap.

2. Cardholder Data Environment (CDE) Scope Definition

2.0 Entity Classification & Reporting Boundary

This document is a Gap Analysis, not a Report on Compliance (ROC), and is intended as the precursor assessment that informs PaySafe India's formal PCI DSS reporting to its acquiring/issuing relationships. PaySafe India's Card Processing Role - "Issuer and Acquirer Processing Services" performed in-house - meets the PCI SSC definition of a service provider (an entity that stores, processes, or transmits account data on behalf of another entity, or that could affect the security of another entity's account data), not merely a merchant accepting its own transactions. Under the card brands' compliance programs, an entity processing at PaySafe India's issuing/acquiring volume is very likely required to validate via an annual ROC signed by a QSA, rather than a Self-Assessment Questionnaire (SAQ). PaySafe India should confirm its validation tier directly with its acquiring relationships and the relevant card brand compliance programs, but this Gap Analysis is written on the working assumption that PaySafe India is a Level 1 service provider for PCI DSS purposes.

This classification is not academic: it changes which sub-requirements apply and at what cadence. Most materially, PCI DSS v4.0 requires service providers to re-perform segmentation testing every six months (Req 11.4.6), rather than the twelve-month cadence that applies to non-service-provider entities (Req 11.4.5). Finding 08 (Section 4.8) is written against the service-provider cadence on this basis; see Section 4.8 for how this changes the finding's remediation timeline.

2.1 Scoping Logic

A system falls inside the CDE if it stores, processes, or transmits account data, or if it is connected to a system that does and lacks adequate segmentation from it. PaySafe India's environment was walked system by system against that test rather than assumed from an architecture diagram, because architecture diagrams describe intent and this assessment is concerned with what the network actually permits.

2.2 In-Scope Systems

- **Payment Processing API** - receives, authorizes, and routes transaction requests for both issuing and acquiring flows; processes PAN and cardholder data on every call. In scope by direct processing.
- **Card Vault** - tokenizes and stores PAN, expiry, and cardholder name; the only system in the estate authorized to hold PAN at rest. In scope by direct storage.
- **Transaction Database** - retains transaction-level records referencing tokenized PAN and, in several legacy tables, truncated PAN for dispute handling. In scope by processing and storage of derived account data.
- **Admin Portal** - used by operations and support staff to view transaction records, issue refunds, and manage merchant onboarding; renders masked PAN to the screen and holds session-level access to the transaction database. In scope because it is directly connected to, and can query, systems that store account data.
- **Settlement Reconciliation Module** - batch job connecting the transaction database to the acquiring bank's settlement files; the subject of Finding 03. In scope by direct processing of unmasked PAN, a fact the prior architecture review had not flagged because the module was categorized as a reporting tool rather than a payment system.
- **Logging/SIEM Platform** - ingests authentication, configuration, and transaction logs from every system above. In scope because CDE log data, including fields that can contain truncated PAN in error conditions, flows through it.

2.3 Out-of-Scope Systems

PaySafe India's marketing website, HR and payroll systems, and general corporate email are treated as out of scope. None of the three stores, processes, or transmits account data, and none has a network path into the CDE: the marketing site is hosted on a separate cloud account with no VPC peering to production, HR and payroll run on an isolated SaaS platform reached only from the corporate (non-CDE) network segment, and corporate email, while used by CDE administrators, does not have file attachments or logging integrations that touch cardholder data systems. This scoping call rests on the segmentation actually in place, not on organizational assurances that these systems are unrelated to payments - the network configuration was reviewed, not just the org chart.

2.4 Segmentation Assessment

Segmentation between the CDE and the rest of PaySafe India's network is inconsistent rather than absent. The card vault and transaction database sit in a dedicated VPC with security-group rules that permit inbound traffic only from the payment processing API and the admin portal, which is sound. The admin portal, however, shares

a VLAN with several internal operations tools that are not otherwise in scope, and firewall rules between that VLAN and the general corporate network allow broad east-west traffic rather than the narrow allow-list the network security control standard calls for - this is the segmentation weakness underlying the Req 1 finding (Section 4.1). It is not a flat network in the way that phrase usually implies; it is a network with one genuinely well-segmented core (the vault and database) attached to a perimeter that is segmented in name more than in enforced rule sets.

2.5 Scope Justification - Excluded Business Lines (UPI, BNPL Lending)

PaySafe India's cover page identifies four business lines - Digital Payments, UPI, BNPL Lending, and Card Processing - but Sections 2.2 and 2.3 above address in-scope and out-of-scope systems only in terms of the card-processing estate. UPI and BNPL Lending are addressed explicitly here so the exclusion is documented as a considered scoping decision rather than an oversight.

UPI. Unified Payments Interface transactions in India are routed and settled using a Virtual Payment Address (VPA) and the UPI switch's own transaction identifiers; no PAN is generated, transmitted, or stored anywhere in the UPI transaction flow, because UPI is architecturally a bank-account-to-bank-account rail rather than a card rail. PaySafe India's UPI platform was reviewed against the CDE scoping test in Section 2.1 (stores, processes, or transmits account data, or is connected to a system that does) and found to have no data-field overlap and no network path into the card-processing CDE - the UPI switch integration and the card-processing systems in Section 2.2 sit on separate network segments with no routing between them. UPI is accordingly out of scope for PCI DSS. This exclusion does not extend to NPCI's own UPI-specific security and audit requirements, which fall outside this assessment's scope but should be tracked separately.

BNPL Lending. The Buy-Now-Pay-Later lending platform underwrites and services credit lines and, at the point of a BNPL transaction, may reference tokenized card or account identifiers issued by the card-processing platform for repayment purposes, but it does not itself store, process, or transmit PAN - it consumes a token reference via an internal API and has no direct database connection to the card vault or transaction database. On that basis BNPL Lending is also out of scope for PCI DSS. This exclusion should be re-tested if the BNPL platform's integration with the card-processing estate changes (for example, if it begins storing PAN directly rather than consuming tokenized references), and PaySafe India's change-management process should flag any such integration change for a scope re-assessment before it goes live.

3. Gap Analysis Master Table

RAG status is assigned per requirement, not per sub-requirement, reflecting the weakest sub-requirement tested. A one-line rationale is given for each; Section 4 pointers apply to every Red and Amber row.

3.0 Risk-Rating and Sampling Methodology

Severity methodology. RAG status in this section reflects control design and operating effectiveness only, independent of impact. Section 6's Critical/High/Medium severity ratings translate each Amber or Red requirement into a remediation-priority tier using a two-factor likelihood/impact assessment: likelihood is driven by how exposed the gap is to an external or unprivileged internal actor (e.g., internet-facing vs. requiring

existing privileged access), and impact is driven by whether the finding involves unmasked account data directly (highest impact) or a control weakness one step removed from direct data exposure (e.g., a lapsed review or missing detection capability). Applying that lens: Findings 03 and 07 rate Critical/High because each involves either live unmasked PAN (Finding 03) or the complete absence of a detective control over cardholder-data access (Finding 07); Finding 05 rates High because orphaned privileged access to the sole PAN-storing system is a direct-impact gap even though no exploitation was observed; Findings 02 and 06 rate Medium because both require an additional step (a leaked shared credential, or a compromise of the analytics vendor's environment) before cardholder data is reachable. This is stated here as a short methodology note; a mature program would formalize it as a standing likelihood/impact matrix (e.g., aligned to NIST SP 800-30 or ISO/IEC 27005) referenced by every future assessment cycle rather than restated each time.

Sampling methodology. Each finding in Section 4 states the evidence type sampled, but the population each sample was drawn from is stated here rather than repeated per finding. Configuration reviews (Findings 01, 02, 04, 06, 07) were performed against the full current configuration state of the named system - a full population, not a sample, since configuration artifacts do not require sampling. Log- and ticket-based evidence was sampled as follows: Finding 01's rule-review evidence was checked against the two most recent semi-annual review windows (the full population of expected review events since the last confirmed review). Finding 03's SFTP archive evidence used a 30-day access-log sample drawn from the most recent full calendar month preceding fieldwork, selected for recency rather than randomization, against a population of roughly 180 days of retained archive activity. Finding 06's vendor remote-access session-log sample covered all sessions in the 60 days preceding fieldwork for the two affected vendor accounts (a full population for those accounts, not a random draw, since the affected account population is small enough to review in full). Interview-based evidence (Findings 01 through 08) was gathered from the single role-holder identified as the control owner or operator for each system; no secondary corroborating interview was conducted, which is a limitation worth noting for any finding where the interview is the primary evidence basis.

3.1 Goal 1 - Build and Maintain a Secure Network and Systems

Req	Requirement	Status	Rationale
1	Install and Maintain Network Security Controls	Amber	NSC rules exist and are largely correct at the CDE core, but the admin-portal VLAN permits east-west traffic broader than the allow-list standard requires, and the required NSC rule-set review has not been evidenced for two consecutive review cycles.
2	Apply Secure Configurations to All System Components	Amber	Hardening baselines are defined and applied to the vault and database tiers, but three legacy transaction-database read replicas retain a vendor-default remote-root account (Req 2.2.2), used by third-party analytics integration, rather than a named individually authenticated account.

3.2 Goal 2 - Protect Account Data

Req	Requirement	Status	Rationale
3	Protect Stored Account Data	Red	The card vault correctly tokenizes PAN at rest, but the settlement reconciliation module exports unmasked PAN to a flat file retained for 180 days - 174 days beyond the five-business-day reconciliation cycle that is the actual business need, a data-retention and disposal failure under Req 3.2.1.
4	Protect Cardholder Data with Strong Cryptography During Transmission	Green	TLS 1.2 minimum is enforced at every external and internal CDE endpoint tested, certificate lifecycle management is current, and no fallback to weak ciphers was observed in configuration review or a sample of captured handshakes.

3.3 Goal 3 - Maintain a Vulnerability Management Program

Req	Requirement	Status	Rationale
5	Protect All Systems and Networks from Malicious Software	Green	EDR is deployed fleet-wide across CDE endpoints and servers, signature and behavioral updates are current, and quarantine logs show the control actioning real detections, not just running idle.
6	Develop and Maintain Secure Systems and Software	Amber	Manual code review is performed for the payment processing API, but SAST is not integrated into the admin portal's CI/CD pipeline, and dependency scanning across both codebases is ad hoc rather than scheduled.

3.4 Goal 4 - Implement Strong Access Control Measures

Req	Requirement	Status	Rationale
7	Restrict Access to System Components and Cardholder Data by Business Need to Know	Red	Role-based access is designed correctly, but the quarterly privileged-access review mandated for the card-vault DBA role (Req 7.2.4) has not been evidenced since Q3 2025, and two service accounts with standing vault access have no identified business owner or documented review cadence (Req 7.2.5/7.2.5.1).
8	Identify Users and Authenticate Access to System Components	Amber	MFA is enforced for employee access into the CDE, but a subset of third-party vendor support accounts connect over VPN using shared, static, group credentials with no MFA (Req 8.2.2), a gap that corroborates Internal Audit Finding 01 (PSI-IA-2026-04).
9	Restrict Physical Access to Cardholder Data	Green	The CDE is hosted in a Tier III colocation facility with badge-plus-biometric access, logged visitor escort procedures, and media handling controls; site walkthrough and log sampling found no exceptions.

3.5 Goal 5 - Regularly Monitor and Test Networks

Req	Requirement	Status	Rationale
10	Log and Monitor All Access to System Components and Cardholder Data	Red	Logs from every in-scope system reach the SIEM, but no correlation rules exist for anomalous cardholder-data access, and daily log review is a manual SOC spot-check rather than the automated review the requirement calls for at this transaction volume.
11	Test Security of Systems and Networks Regularly	Amber	Internal and external penetration testing is current and well-documented, but segmentation testing under the service-provider cadence (Req 11.4.6) was not re-performed after the admin portal Q2 2026 redeployment, which is exactly the kind of significant change that triggers the requirement.

3.6 Goal 6 - Maintain an Information Security Policy

Req	Requirement	Status	Rationale
12	Support Information Security with Organizational Policies and Programs	Green	The information security policy set built for the ISO/IEC 27001:2017 programme (Gap Analysis v1.0) already covers the PCI-required elements - annual review, role-based responsibility assignment, a documented awareness-training cycle - with no material gap identified.

4. Detailed Findings - Evidence Sampling

Every finding below corresponds to a Red or Amber row in Section 3. Each cites the evidence type actually sampled - no finding here rests on a bare status label.

4.1 Finding 01 - Network Security Control Rule-Set Review Lapsed (Req 1.2.7, Req 1.4.1)

Gap description: The admin-portal VLAN's firewall permits broad east-west traffic to internal operations tools that are not part of the CDE, rather than the narrow, documented allow-list Req 1.2.7 requires, and the semi-annual NSC rule review required by Req 1.4.1 has not been evidenced since November 2025.

Evidence basis: Configuration review of the firewall rule base for the admin-portal VLAN, cross-referenced against the change-management ticket log; no rule-review sign-off artifact was located for the two most recent review windows.

Risk if unremediated: An attacker who compromises any system on the shared VLAN inherits a viable path toward the admin portal without needing to breach the CDE's outer perimeter first, materially reducing the effort required to reach systems that touch cardholder data.

4.2 Finding 02 - Legacy Database Replicas Retain Default Remote-Root Access (Req 2.2.2)

Gap description: Three read-replica instances of the transaction database, kept live to feed a third-party analytics integration, still expose the vendor-default remote-root account rather than the named, individually-authenticated accounts Req 2.2.2 requires vendor-default accounts to be either disabled/removed or reconfigured to.

Evidence basis: Configuration review of database instance settings via the cloud provider's console export, corroborated by an interview with the database platform owner, who confirmed the analytics vendor's connector will not authenticate against a non-root account without a version upgrade that is not yet scheduled.

Risk if unremediated: A single leaked or brute-forced credential provides full administrative access to a copy of transaction data, and because the account is shared rather than individual, any compromise is invisible in audit logs that rely on username attribution. This is a vendor-driven gap - the analytics vendor's connector, not PaySafe India's own configuration, is the blocking dependency - and should be tracked against that vendor's tier and contractual security obligations under PaySafe India's TPRM Framework (v1.0) rather than managed solely as an internal configuration finding; the remediation roadmap (Section 6.3) names Vendor Management as a co-owner for this reason.

4.3 Finding 03 - Unmasked PAN Retained in Settlement Export Files Beyond Business Need (Req 3.2.1, Req 3.5.1)

Gap description: The settlement reconciliation module writes a daily flat file containing unmasked PAN to an internal SFTP archive so that it can be matched line-by-line against the acquiring bank's settlement report. The reconciliation cycle itself completes within five business days, but the files are retained for 180 days under a legacy backup policy that was never updated when the reconciliation process was automated.

Evidence basis: Log sample of 30 days of SFTP archive access and retention metadata, combined with an interview with the settlement operations lead, who confirmed the 180-day figure was inherited from an unrelated general-ledger retention schedule and was not a deliberate business decision.

Risk if unremediated: Cardholder data exists in cleartext, outside the tokenization boundary, for roughly 35 times longer than any legitimate business process requires, and the archive's access controls are the same as the general file server rather than CDE-grade - this is the finding with the highest realistic breach impact in this assessment.

4.4 Finding 04 - SAST Not Integrated into Admin Portal CI/CD; Dependency Scanning Ad Hoc (Req 6.2.4, Req 6.3.2)

Gap description: The payment processing API has manual secure code review at each release, but the admin portal - which has direct query access to the transaction database - ships through a CI/CD pipeline with no automated static analysis gate, and third-party dependency scanning across both codebases happens only when a developer remembers to run it.

Evidence basis: Configuration review of both CI/CD pipeline definitions, plus interview with the engineering lead responsible for the admin portal, who confirmed no SAST tooling is wired into the merge gate.

Risk if unremediated: Injection and access-control defects in the admin portal - the system with the broadest query surface over cardholder-adjacent data - can reach production without any automated check, relying entirely on a manual review step that is not consistently applied.

4.5 Finding 05 - Privileged Access Review for Card-Vault Roles Lapsed Three Quarters (Req 7.2.4, Req 7.2.5/7.2.5.1)

Gap description: Access Control Policy (v1.0) mandates quarterly review of privileged roles with access to cardholder data. The card-vault database administrator role - a human privileged account governed by Req 7.2.4's fixed six-month review cadence - has not had a documented review since Q3 2025. Separately, two service accounts with standing vault access - used historically by a decommissioned batch job - have no identified business owner able to justify continued access; because these are application/system accounts rather than human accounts, they fall under Req 7.2.5/7.2.5.1, which requires access to be appropriately assigned and periodically reviewed based on the entity's targeted risk analysis rather than the fixed cadence that applies to Req 7.2.4. Both control types have lapsed here, but they are distinct requirements with different review triggers and should not be treated as a single citation.

Evidence basis: Policy document review against the access-review ticket history in the ITSM system, and an interview with the vault platform owner, who could not identify a current business justification for the two orphaned service accounts.

Risk if unremediated: Access to the single system authorized to hold PAN at rest is not being actively validated, meaning privilege creep or an orphaned credential could sit undetected for a year or more; this finding also creates a DPDP purpose-limitation exposure discussed in Section 7.2.

4.6 Finding 06 - MFA Not Enforced for Third-Party Vendor Remote Support Access (Req 8.4.2, Req 8.2.2)

Gap description: Employee access to the CDE requires MFA without exception, but a subset of third-party vendor support accounts - used by the card-vault platform vendor and one payment-gateway integration partner - connect over VPN using shared, group, static credentials with no second factor, contrary to Req 8.2.2's requirement that group/shared/generic accounts only be used when necessary and be managed under defined conditions.

Evidence basis: Configuration review of the VPN authentication policy and a sample of vendor remote-access session logs; interview with the vendor management lead confirmed the affected vendors have not yet completed onboarding to the MFA-capable access gateway rolled out to employees in 2025.

Risk if unremediated: A single leaked shared credential grants remote access into the CDE with no second factor and no reliable attribution to an individual, and this gap independently corroborates Internal Audit Finding 01 (PSI-IA-2026-04), which flagged the same MFA inconsistency from the access-governance side rather than the vendor-management side. Like Finding 02, this gap traces to onboarding delays at two specific vendors rather than an internal control design failure, and should be tracked against those vendors' risk tier and monitoring obligations under the TPRM Framework (v1.0) in addition to the technical jump-host remediation in Section 6.2.

4.7 Finding 07 - No Automated Log Review or Correlation for Cardholder Data Access (Req 10.4.1.1)

Gap description: The SIEM platform receives logs from every in-scope system, but no correlation rules have been configured to flag anomalous access to cardholder data, and the daily log review required by Req 10.4.1 is performed as a manual SOC analyst spot-check across a fraction of total log volume rather than the automated mechanism the requirement expects at PaySafe India's transaction throughput.

Evidence basis: Configuration review of the SIEM's active rule set (zero rules tagged to cardholder-data access patterns), and interview with the SOC lead, who estimated manual review covers under 15% of daily log volume.

Risk if unremediated: Log data is being collected but not meaningfully reviewed, which means unauthorized or anomalous access to cardholder data - including the kind of access pattern that would flag Finding 03 or Finding 05 in real time - is unlikely to be detected before an external party surfaces it.

4.8 Finding 08 - Segmentation Testing Not Re-Performed After Significant Change (Req 11.4.6)

Gap description: Internal and external penetration testing is current, but as a PCI DSS service provider (Section 2.0), PaySafe India is subject to Req 11.4.6, which requires segmentation testing every six months and after any significant change to segmentation controls - not the twelve-month, standard-entity cadence under Req 11.4.5. The admin portal's Q2 2026 redeployment, which altered the VLAN referenced in Finding 01, is exactly such a significant change and has not triggered a re-test under either cadence.

Evidence basis: Policy document review of the change-management record for the Q2 2026 admin-portal redeployment, cross-referenced against the penetration-testing schedule, which shows the next segmentation test is currently scheduled for the annual cycle in November 2026 - a schedule built around the twelve-month cadence that this finding argues does not apply to PaySafe India.

Risk if unremediated: The organization is operating on segmentation assumptions that have not been validated since a change that specifically touched the boundary in question, which means Finding 01's east-west traffic issue could be worse in practice than the configuration review alone indicates. Beyond the technical risk, scheduling the re-test against the wrong cadence (11.4.5 instead of 11.4.6) is itself a compliance gap independent of the underlying network finding - PaySafe India's next segmentation test should be scheduled within six months of the Q2 2026 change, not deferred to the November 2026 annual cycle.

5. Compensating Controls Analysis

Three findings were evaluated for compensating controls because each involves a genuine constraint - legacy dependency or unsupported vendor protocol - rather than simple inaction. Each proposed control is tested against all four PCI DSS conditions. Where a control does not clearly satisfy all four, that is stated plainly rather than papered over.

5.1 Compensating Control 1 - Interim Protection for the Settlement PAN Export (Finding 03, Req 3.5.1)

The constraint: the settlement reconciliation module depends on a third-party core-banking connector that reconciles against the acquirer's settlement file using plaintext PAN matching, and the connector will not be upgraded to accept tokenized references until the vendor's Q1 2027 release. A full fix is therefore months away; PaySafe India needs an interim control now.

Proposed control: encrypt each settlement export file with envelope encryption at the moment of generation, restrict decryption-key access to two named settlement operations staff, cut the retention period from 180 days to the actual seven-business-day reconciliation-plus-dispute window, and add a SIEM alert on any access to the archive outside the settlement job's own service account.

Condition	Assessment
1. Meets the intent of the original requirement	Yes - the intent of Req 3.5.1 is that PAN at rest is unreadable to anyone without a specific, controlled need; envelope encryption plus a two-person key-access list achieves that for the export files specifically.
2. Provides a similar level of defense	Yes, for the retention window it actually covers - a compromised archive yields nothing without the decryption key, which is functionally equivalent to the protection tokenization provides elsewhere.
3. Above and beyond other PCI DSS requirements	Partially. Encryption of stored data is already required by Req 3.5.1 itself, so encrypting the export file is arguably restating the requirement rather than exceeding it. The retention cut and the dedicated access alerting are genuinely additive and are the stronger part of the justification here.
4. Commensurate with the additional risk	Borderline. The retention cut from 180 to 7 days removes most of the excess exposure, but the underlying architecture still writes unmasked PAN to disk daily, which is a materially higher-risk pattern than tokenization even with encryption layered on top.

This control is approved as an interim measure only, and a QSA signing off on this in a real assessment should expect to see the vendor upgrade timeline in writing before accepting it past one review cycle. Condition 3 is the weak point - restating an existing encryption requirement is not the same as exceeding it - and PaySafe India should not present this as a durable fix in next year's assessment.

5.2 Compensating Control 2 - Hardened Jump Host for Vendor Remote Support (Finding 06, Req 8.4.2)

The constraint: the card-vault platform vendor's diagnostic tooling authenticates only via a legacy VPN client that does not support SAML or OIDC, and therefore cannot be enrolled in the MFA-capable access gateway used for employee and other vendor access.

Proposed control: route all vendor remote-support sessions through a dedicated jump host that itself requires MFA, records every session, and is reachable only from the vendor's pre-registered source IP range for a time-boxed window opened per support ticket rather than left standing.

Condition	Assessment
1. Meets the intent of the original requirement	Yes - the intent of Req 8.4.2 is that remote access into the CDE cannot proceed on a single factor; the jump host enforces MFA at the point of entry even though the legacy client behind it cannot.
2. Provides a similar level of defense	Yes - session recording and time-boxed access windows arguably provide more visibility into vendor activity than standard MFA alone would.
3. Above and beyond other PCI DSS requirements	Yes - session recording and ticket-gated time-boxing are not baseline requirements for standard remote access and represent a genuine addition.
4. Commensurate with the additional risk	Yes - the residual risk (a legacy client with no MFA) is fully bounded by the jump host, which is the only path to reach it.

This control satisfies all four conditions and is approved without qualification, subject to a documented commitment that the vendor's platform will be re-evaluated at contract renewal for a client that supports modern authentication directly.

5.3 Compensating Control 3 - Proposed Segmentation for Legacy Analytics Database Access (Finding 02, Req 2.2.2) - Not Approved

The constraint: the third-party analytics integration reading from the transaction-database replicas authenticates only via the vendor-default remote-root account and cannot be reconfigured to a least-privilege account without a connector version upgrade the vendor has not committed a date for.

Proposed control (evaluated, not approved): restrict network connectivity to the replicas so that only the analytics tool's fixed IP address can reach the remote-root listener, disable remote-root access from every other source, and add alerting on any authentication attempt outside that IP.

Condition	Assessment
1. Meets the intent of the original requirement	No. Req 2.2.2's intent is that administrative access is individually attributable and least-privilege; network-restricting a still-shared, still-root credential does not change what the account can do once a connection is established from the permitted source.
2. Provides a similar level of defense	No. If the analytics tool's environment is itself compromised, the attacker inherits full root access from an already-whitelisted path -

Condition	Assessment
	the control narrows the attack surface but does not reduce the blast radius of the credential itself.
3. Above and beyond other PCI DSS requirements	Partially - the IP restriction and alerting are additive, but they are compensating for a network-layer problem while the actual gap is at the identity layer.
4. Commensurate with the additional risk	No - the risk being compensated for (a shared root credential with no individual attribution) is not proportionate to a network-layer mitigation.

This proposed control fails conditions 1, 2, and 4 and is not approved. The honest path here is remediation, not a workaround: PaySafe India should either push the vendor for an expedited connector upgrade or, if that timeline is unacceptable, provision a least-privilege replica account and accept the short-term cost of adapting the analytics integration to use it. The network restriction can run alongside remediation as defense-in-depth, but it should not appear in next year's report as a control that closed this finding.

6. Remediation Roadmap

Every Red and Amber finding is prioritized below by severity into three horizons. Owners are named by role, not by individual, consistent with PaySafe India's other governance deliverables. This client-facing report is a summary; the full workpaper set maintained internally by the assessment team includes a separate, internal-only appendix mapping each role above (and each interview cited in Section 4's evidence-basis narratives) to a named individual and interview date. That appendix is not reproduced here because it is not needed for the client-facing summary, but it should be retained and available on request for any subsequent ROC-level review.

6.1 Immediate (0-30 days) - Critical Findings

Finding	Owner Role	Effort	Dependency Notes
Finding 03 - PAN export retention & encryption	Head of Settlement Operations, with CISO sign-off	~₹4-6 lakh; 2 engineer-weeks	Blocked on key-management provisioning for envelope encryption; interim control per Section 5.1 pending core-banking connector upgrade (vendor Q1 2027).
Finding 05 - Privileged access review, card vault	Identity & Access Management Lead	1 engineer-week	Depends on business-owner sign-off for the two orphaned service accounts; recommend immediate suspension of both pending review
Finding 07 - SIEM correlation rules for PAN access	SOC Lead, in coordination with Detection Engineering	~₹8-10 lakh; 3-4 engineer-weeks	Depends on budget approval for correlation-rule development; can begin immediately using

Finding	Owner Role	Effort	Dependency Notes
			existing SIEM licensing with no new procurement.

6.2 Short-term (30-90 days) - High Findings

Finding	Owner Role	Effort	Dependency Notes
Finding 06 - MFA for vendor remote support	Vendor Management Lead, with Network Security	~₹3-5 lakh; jump-host build 3 engineer-weeks	Depends on vendor cooperation to migrate session routing; compensating control (Section 5.2) can go live before full remediation.
Finding 01 - NSC rule-set allow-list and review cadence	Network Security Engineering Lead	2-3 engineer-weeks	Depends on completion of Finding 08's segmentation re-test to confirm the new rule set actually restores the intended boundary.
Finding 08 - Segmentation re-test after admin portal change	External Penetration Testing Vendor, commissioned by CISO	~₹6-8 lakh; 1 testing cycle	Blocked on vendor scheduling; under the service-provider six-month cadence (Req 11.4.6, Section 2.0), this re-test is due within 6 months of the Q2 2026 change, not the November 2026 annual cycle, so it should be commissioned immediately rather than merely expedited. Also unblocks the Finding 01 dependency noted below.

6.3 Medium-term (90-180 days) - Medium Findings

Finding	Owner Role	Effort	Dependency Notes
Finding 02 - Legacy database replica remote-root access	Database Platform Owner, with Vendor Management	~₹10-15 lakh; connector upgrade + 4 engineer-weeks	Blocked on analytics vendor's connector release; if timeline slips past 180 days, escalate to CISO for a forced least-privilege migration regardless of integration cost.
Finding 04 - SAST integration and scheduled dependency scanning	Engineering Lead, Admin Portal	~₹5-7 lakh; 3 engineer-weeks	Depends on CI/CD tooling procurement approval; no external blocker once budget clears.

7. DPDP 2023 Alignment Note

PCI DSS gaps in a fintech processing Indian consumers' payment data are rarely just card-data problems. Two of this assessment's findings sit directly on top of obligations under the Digital Personal Data Protection Act, 2023,

and a regulator or auditor who looks at both frameworks at once will read these as the same failure described twice, not two unrelated issues.

7.1 Requirement 3 and Data Minimization / Storage Limitation

Finding 03's 180-day retention of unmasked PAN - 174 days past the actual reconciliation need - is a PCI storage-limitation failure under Req 3.2.1 (account data storage minimized through retention and disposal policy), but it is equally a DPDP data-minimization failure: Section 8(7) of the DPDP Act requires personal data to be retained only as long as necessary for the purpose for which it was collected and processed, and cardholder name and PAN are personal data under the Act regardless of their PCI classification. Retaining the data for a purpose (reconciliation) that concluded within seven days, for a period 25 times longer than that purpose required, is difficult to defend to the Data Protection Board of India as anything other than retention without a lawful basis for the excess period.

7.2 Requirement 7 and Purpose Limitation / Access Governance

Finding 05's lapsed access review for card-vault privileged roles (Req 7.2.4), and specifically the two orphaned service accounts with no identifiable business owner (Req 7.2.5/7.2.5.1), is a PCI need-to-know failure - but under DPDP, access without a current, documented purpose is exactly the access-governance failure the Act's purpose-limitation principle is meant to prevent. An access grant that nobody can currently justify is, by definition, access that has outlived whatever purpose originally justified it, which is the same defect DPDP addresses from the data-subject-rights side.

7.3 Compounding Regulatory Exposure

The compounding consequence is straightforward: a PCI QSA finding and a DPDP compliance gap arising from the same root cause give a regulator two independent bases to act on a single control failure. RBI's data-localization and payment-security directions, MeitY's broader data-protection oversight role, and the Data Protection Board of India's enforcement powers under DPDP are not mutually exclusive - a breach traced back to the Finding 03 export file could trigger a PCI-driven card-network liability shift and a DPDP penalty simultaneously, off the same underlying fact pattern. PaySafe India's remediation plan for Findings 03 and 05 should therefore be framed to both control owners and the board as closing a single compliance exposure with two regulatory faces, not as two separate line items competing for the same engineering time.